Exp 8: Configuring User Management and Role-Based Access Control (RBAC) in a Zoho Creator Application

1. Aim

To configure user management and role-based access control in the Student Admission Management application built in Zoho Creator, by defining permission profiles, building a role hierarchy, adding a new user who is invited by email, and checking that each user sees only the records and components that the assigned role and permission allow.

2. Procedure

2.1 Access Control Requirements

Without access control, every person who signs in to the application can see and change every admission enquiry. Four requirements were set so that each person gets only the access the job needs, as listed in Table 1.

Requirement	Component	Details
Define what a user may do	Permission profiles	Admission Staff, Read and Write, created under Settings > User Permissions > Permissions
Define who reports to whom	Role hierarchy	CEO > Admission Manager > Admission Staff, created under the Roles tab
Control which records a user can see	Role position and Data Sharing	Records of a role are visible to the roles above it; sharing with peers is a switch on each role
Bring a new person into the application	Add User and email invitation	User added from Users in the Creator home; the person confirms the account from the invitation email

Table 1: Access control requirements and the components used

2.2 Creating the Permission Profiles

A permission profile is a named set of rights that is attached to a user. The profiles were opened from **Settings > User Permissions** of the Student Admission Management application, on the *Permissions* tab (Figure 1). Three profiles are available, as shown in Table 2.

Profile	Description
Admission Staff	Allows admission staff to access and manage student admission enquiries
Read	Read permission for all components of the application
Write	Write permission for all components of the application

Table 2: Permission profiles defined in the application

Admission Staff is a custom profile limited to the admission enquiries, whereas Read and Write are the general profiles that apply to every component. New profiles are added with the **Add Permission** button.

2.3 Creating the Role Hierarchy

Roles decide whose records a user can see. They were created from the *Roles* tab using the **Add Role** panel (Figure 2), which asks for the following:

- **Name:** the title of the role, for example Admission Manager.
- **Reports to:** the role directly above it in the hierarchy. CEO is the top role, so the first new role reports to CEO.
- **Description:** a short note on what the role is for.

- **Share Data with Peers:** a checkbox that lets users holding the same role see each other's records. It was left off, so each person sees only their own records and those of the roles below.

After saving, the roles were arranged as a three-level tree (Figure 3): CEO at the top, Admission Manager reporting to CEO, and Admission Staff reporting to Admission Manager. A user at a higher level can see the records of the levels below, while a user at the lowest level sees only their own.

2.4 Adding a User and Sending the Invitation

Users are managed from **Users** in the Creator home page, under the Manage section of the left menu (Figure 4). The **Add User** button opens a form for the new person's name and email address, where the role and the permission profile are chosen. Creator then sends an invitation email from the Zoho Creator Team to that address (Figure 5), and the person must click *Confirm Account* to join the organisation. The list of all users shows each person with the email address and the status Active once the account is confirmed. The first entry carries the Super Admin label, which has full control of the organisation.

2.5 Testing the Access Control

The configuration was tested by signing in as the different users and checking what each could open. Table 3 lists the cases covered and the behaviour the settings are designed to give.

Test case	Setup	Expected behaviour
Invitation	New user added with an email address	The person receives the invitation email and can confirm the account (Figure 5)
Account status	Invitation confirmed	The user appears in the All Users list with the status Active (Figure 4)
Staff access	User with the Admission Staff role and permission	Can open and manage admission enquiries, but not the other components
Manager view	User with the Admission Manager role	Sees the records of Admission Staff in addition to their own
Admin access	Super Admin	Has full access to all users, roles, permissions and applications

Table 3: Test cases for user management and RBAC

3. Output

The following figures show the permission profiles, the Add Role panel, the role hierarchy, the list of users and the invitation email.

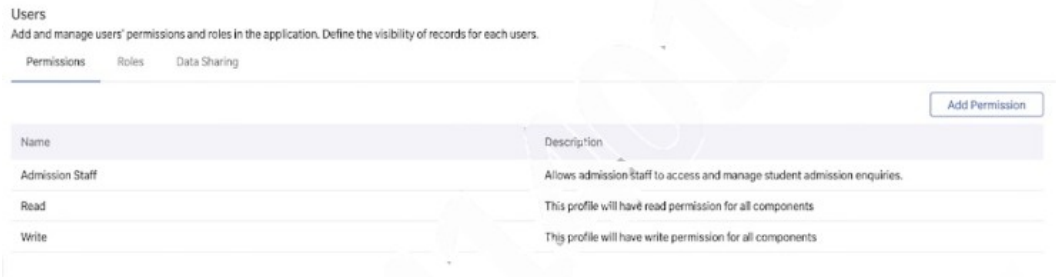


Figure 1: Permissions tab showing the Admission Staff, Read and Write profiles

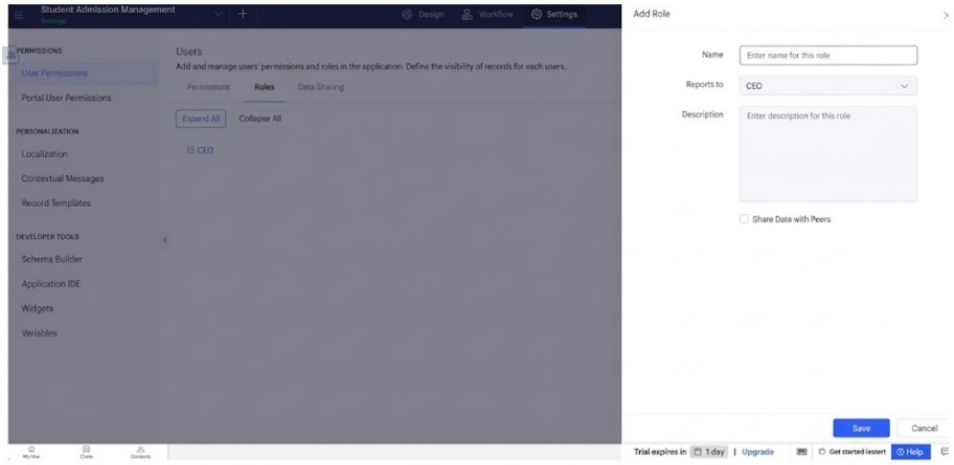


Figure 2: Add Role panel with Name, Reports to, Description and Share Data with Peers

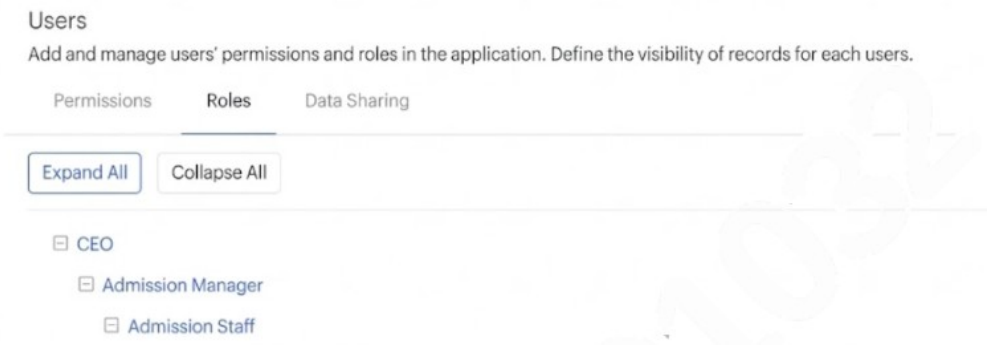


Figure 3: Role hierarchy CEO > Admission Manager > Admission Staff

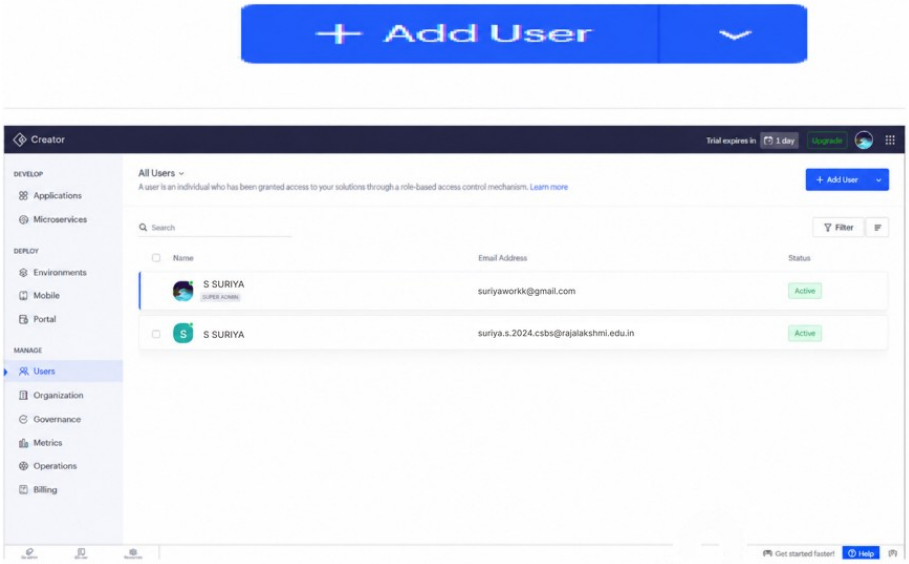


Figure 4: Users page with the Add User button and the list of users with status Active

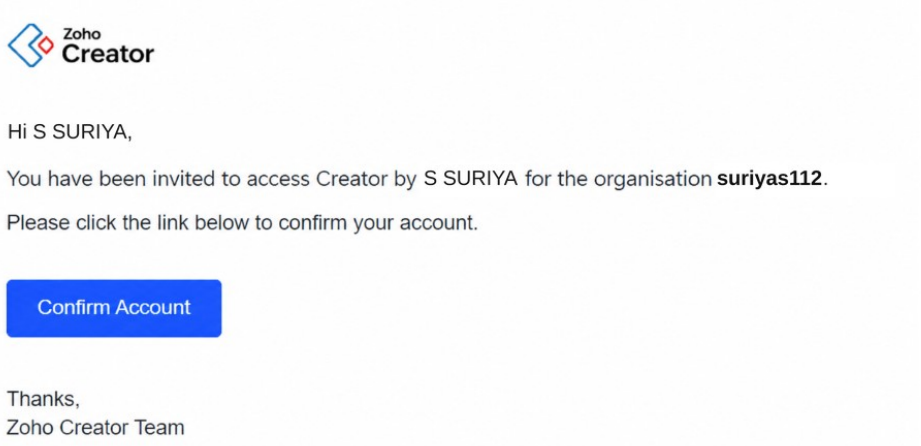


Figure 5: Invitation email from the Zoho Creator Team with the Confirm Account link

Observations from the output

- Permissions say what a user can do, and roles say whose records the user can see, so the two are set separately and combined for each user.
- The role tree follows the real reporting line of the admission office, so a manager sees the work of the staff without any record being shared by hand.
- A new user cannot enter the application until the invitation is confirmed, so only the owner of the email address gets access.
- The Super Admin label marks the account with full control, which should be kept to as few people as possible.

4. Result

User management and role-based access control were configured in the Student Admission Management application in Zoho Creator. Permission profiles were defined, a CEO, Admission Manager and Admission Staff role hierarchy was built, and a new user was added and invited by email. This completes the user management and access control requirements of this experiment.

24401'z